

Phantom Invoice

Email Forensic Analysis

Business Email Compromise (BEC) & Invoice Fraud Investigation

Presented by: Group 1 | Date: 29th May 2026

Executive Summary

Item	Summary
Attack Type	Business Email Compromise (BEC) / Invoice Fraud
Target	Accounts Payable Department, Nexus Logistics Group
Attack Duration	3-day window across 3 emails
Requested Amount	\$47,000 USD
Outcome	Intercepted by IT Security – No financial loss
Impersonated Roles	CFO (James Hargrove) & Vendor (Meridian Freight Solutions)

The attacker impersonated two critical roles — a CFO and a vendor — to build layered credibility and pressure the Accounts Payable team.

Email Chain Overview

Email	Sender (Fake)	Subject	Date
Email 1	j.hargrove@nexus-logistics.com (Fake CFO)	URGENT: Vendor Payment Authorization Required Today	Mon, 11 Mar
Email 2	billing@meridianfreight-solutions.net (Fake Vendor)	Re: URGENT: Vendor Payment Authorization Required Today	Tue, 12 Mar
Email 3	James Hargrove CFO	Re: ... — FINAL NOTICE	Wed, 13 Mar

Attack Progression



Lookalike Domain (Homoglyph Attack)

LEGITIMATE DOMAIN

nexuslogistics.com

(lowercase L)

≠

ATTACKER DOMAIN

nexus-Iogistics.com

(uppercase I replaces lowercase l)

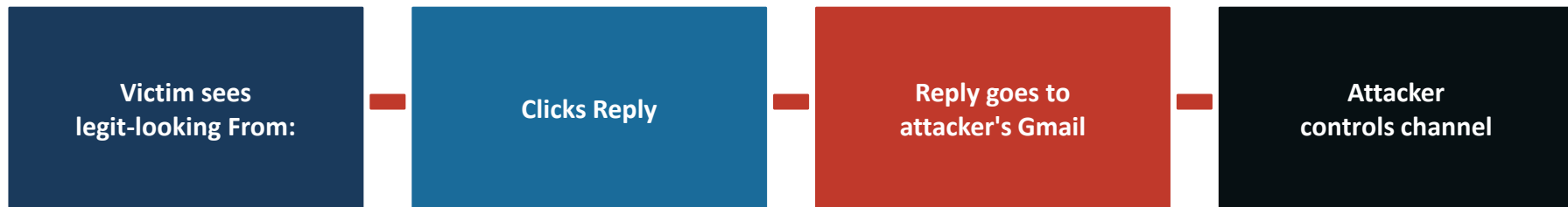
This is a homoglyph (typosquatting) attack. By replacing a lowercase 'l' with an uppercase 'I', the two domains appear visually identical in most fonts — nearly impossible to detect at a glance.

Legitimate Domain	Attacker Domain	Deception Method
nexuslogistics.com	nexus-logistics.com	Uppercase I replaces lowercase l

Header Discrepancies (Reply-To Trap)

Header	Value	Red Flag
From:	j.hargrove@nexus-logistics.com	Fake lookalike domain
Reply-To:	j.hargrove.cfo@gmail.com	Personal Gmail – not corporate
Return-Path:	bounce@smtp.webmailpro.xyz	Attacker-controlled SMTP server

How the Reply-To Trap Works



Authentication Failures (SPF/DKIM/DMARC)

SPF

Email 1 & 3:

✗ FAIL

Email 2:

⚠ Softfail

Sending IP
not authorized

DKIM

Email 1 & 3:

✗ NONE

Email 2:

✗ NONE

No signature
whatsoever

DMARC

Email 1 & 3:

✗ FAIL

Email 2:

✗ FAIL

Domain
misalignment

All three authentication mechanisms failed — definitive technical proof that these emails are fraudulent. SPF failed (IP not authorized), DKIM was absent, DMARC failed due to domain misalignment.

Business Impact (If Attack Succeeded)

Category	Impact
Direct Financial	\$47,000 irreversible loss
Supply Chain	Legitimate vendor unpaid → operational halt
Reputational	Loss of client/vendor trust
Resource Drain	Incident response, legal, regulatory costs
Downstream Risk	Signals vulnerability → more aggressive attacks

Financial loss is immediate, but supply chain disruption, reputational damage, and increased targeting are equally severe long-term risks.

IP Geolocation & Received Headers

Artifact	Value
Originating IP	185.234.219.101
Host Domain	smtp.webmailpro.xyz
Geolocation	Austria (Central Europe)
Infrastructure Type	Generic VPS / Hosting provider

Key Finding

Origin

IP 185.234.219.101 resolves to Austria — completely unrelated to Nexus Logistics or Meridian Freight US operations.

Infrastructure

Hosted on a generic VPS (smtp.webmailpro.xyz) — a throwaway server used by the attacker to avoid detection.

No Malicious Payload – Pure Social Engineering

Item	Status
Attachments (.exe, .pdf, .lnk)	X None present
Embedded URLs / Hyperlinks	X None present
Attack Method	Pure text-based social engineering

Why No Payload?

Bypasses SEGs

Secure Email Gateways scan for malicious attachments & URLs. No payload = no triggers.

Bypasses AV

Antivirus tools look for executable payloads. Text-only emails pass through undetected.

Pure Psychology

The attack relies entirely on human manipulation — urgency, authority, and fear — not malware.

Social Engineering Tactics

Tactic	Evidence from Email
Urgency	"process this NOW", "FINAL NOTICE", "extremely urgent"
Isolation	"Do NOT call anyone, Do NOT escalate this"
Fear	\$380,000 contract at risk over \$47,000 invoice
Authority	"board level authorization, I am extremely disappointed"
False Unavailability	"out of contact for 4 hours, closed negotiations"

The attacker used 5 psychological levers simultaneously. Urgency prevents critical thinking. Isolation blocks verification. Fear creates emotional pressure. Authority demands compliance. False unavailability explains why the CFO can't be reached.

MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Evidence in This Attack
Resource Development	T1583.001	Acquire Infrastructure: Domains	Registered nexus-loqistics.com homoglyph domain
Resource Development	T1586.002	Compromise Accounts: Email	smtp.webmailpro.xyz used as attacker-controlled mail relay
Initial Access	T1566.001	Phishing: Spearphishing Attachment	Targeted spearphish to Accounts Payable — no attachment but direct email
Initial Access	T1598.003	Phishing for Information: Spearphishing Link	Reply-To trap redirected replies to attacker Gmail
Defense Evasion	T1036.005	Masquerading: Match Legitimate Name	Homoglyph domain visually identical to real corporate domain
Defense Evasion	T1656	Impersonation	Impersonated CFO James Hargrove & vendor Meridian Freight Solutions
Impact	T1657	Financial Theft	\$47,000 USD wire transfer requested; intercepted before execution

Reconnaissance

Resource Dev

Initial Access

Defense Evasion

Impact

★ Highlighted tactics are confirmed active in this investigation

Remediation & Prevention

TECHNICAL CONTROLS

Email Authentication

Enforce SPF, DKIM & DMARC policies. Reject or quarantine emails that fail all three.

Domain Monitoring

Deploy tools to detect lookalike/homoglyph domains targeting your brand.

Secure Email Gateway

Enable advanced threat protection with sandboxing and sender reputation checks.

PROCESS & POLICY CONTROLS

Dual-Approval for Payments

Require two independent approvers for any wire transfer or vendor payment change.

Out-of-Band Verification

Always verify payment change requests via phone using a known number — never reply to the email.

No-Urgency Policy

Establish that legitimate CFOs and vendors never demand same-day payment by email alone.

Vendor Change Protocol

Changes to banking details must follow a formal written process with document verification.

 **Security Awareness Training** — Run regular BEC simulation exercises so staff recognise urgency manipulation, authority impersonation, and Reply-To traps before a real attack lands.

Key Takeaways

- Homoglyph domains are nearly invisible to the human eye
- SPF / DKIM / DMARC failures are definitive technical proof of fraud
- No payload ≠ No threat — social engineering alone can cause \$47K+ losses
- 5 simultaneous psychological tactics were deployed to bypass human judgment
- Intercepted by IT Security — zero financial loss

THANK YOU